

AFRIZAL WAHYU ADI PUTRA

Cybersecurity Researcher & Penetration Tester

Kota Tasikmalaya, Indonesia | afrizalwahyuadi66@gmail.com
Linkedin: [Afrizal Wahyu Adi Putra](#) | Portfolio/Blog: hackaja.my.id

PROFILE

Saya adalah seorang *Cybersecurity Researcher* dan Mahasiswa Teknik Informatika yang memiliki dedikasi tinggi di bidang *Offensive Security*, *Vulnerability Assessment* and *Penetration Testing* (VAPT). Memiliki latar belakang riset mandiri dan eksplorasi keamanan siber sejak tahun 2017, serta mulai memfokuskan diri sebagai praktisi di bidang *Penetration Testing* sejak tahun 2023. Memiliki rekam jejak dalam mengidentifikasi kerentanan kritis pada infrastruktur pemerintah nasional melalui kolaborasi strategis dengan POLRI. Ahli dalam metodologi pengujian *Black Box* dan *Grey Box*, teknik *WAF Bypass*, serta pengembangan *automated security engine* dengan pendekatan etika *White Hat* yang kuat.

PENGALAMAN PROFESIONAL & PROYEK KEAMANAN

Security Researcher - Government Authorized Testing

Kolaborasi Strategis dengan POLRI & Instansi Pemerintah

Desember 2025 – Sekarang

- Melakukan *Penetration Testing* legal pada infrastruktur digital kementerian dan lembaga pemerintah di bawah otoritas kepolisian dengan metodologi *Black Box* dan *Grey Box*.
- Menyusun laporan teknis komprehensif (*Vulnerability Assessment Report*) yang mencakup temuan, bukti eksploitasi (*PoC*), dan langkah mitigasi untuk tim infrastruktur.
- Temuan Keamanan Terpilih yang Diotorisasi (Kolaborasi dengan POLRI & Lembaga Pemerintah):

1. Information Exposure via Debug Endpoint – POLRI

- Target:** *.polri.go.id
- Vulnerability Type:** Security Misconfiguration (OWASP A05:2021) / CWE-215: Information Exposure Through Debug Information
- Technical Description:** Endpoint /api/debug/pprof/ yang seharusnya hanya tersedia pada lingkungan pengembangan (development) terekspos ke publik. Endpoint ini menyediakan data profil memori, stack trace, dan konfigurasi runtime server.
- Methodology:** Ditemukan melalui enumerasi endpoint dengan fuzzing wordlist umum (/debug/pprof, /pprof, /api/debug/pprof) dan konfirmasi melalui response status 200 serta konten yang menunjukkan data profiling.
- Impact:** Potensi kebocoran informasi sensitif yang dapat digunakan penyerang untuk memahami arsitektur internal server, memetakan fungsi, dan mempersiapkan serangan lebih lanjut.
- Mitigation:** Menonaktifkan endpoint debug pada lingkungan produksi atau membatasi akses hanya melalui jaringan internal dengan autentikasi yang ketat.

2. Unprotected API Endpoint & Sensitive File Exposure – KEMENDAG

- Target:** *.kemendag.go.id
- Vulnerability Type:** Information Disclosure / Unprotected API Endpoint (CWE-200)
- Technical Description:** Ditemukan endpoint publik yang tidak terproteksi, serta file konfigurasi sensitif yang dapat diakses publik:
 - *.kemendag.go.id/.bash_history
 - *.kemendag.go.id/.mysql_history
 - *.kemendag.go.id/.config/
- Methodology:** Dilakukan crawling dan fuzzing terhadap direktori umum untuk menemukan file tersembunyi (hidden files) yang sering tertinggal oleh administrator.

- *Impact:* File .bash_history dapat membocorkan perintah yang pernah dijalankan di server, termasuk potensi kredensial. File .mysql_history dapat berisi query database yang mengandung password atau struktur data internal.
- *Mitigation:* Menerapkan konfigurasi web server yang memblokir akses publik terhadap file dengan awalan titik (dotfiles) dan menghapus file historis dari direktori publik.

3. .htaccess Exposure – Kementerian Koordinator Bidang Perekonomian (EKON)

- *Target:* *.ekon.go.id
- *Vulnerability Type:* Security Misconfiguration (OWASP A05:2021) / CWE-200: Exposure of Sensitive Information
- *Technical Description:* File .htaccess yang berfungsi sebagai konfigurasi front controller untuk server Apache terekspos dan dapat diakses publik. File ini sering digunakan untuk mengatur aturan rewrite, pembatasan akses, dan pengaturan keamanan dasar.
- *Methodology:* Ditemukan melalui enumerasi file konfigurasi umum dengan wordlist yang mencakup .htaccess, .htpasswd, dan varian direktori.
- *Impact:* Penyerang dapat mempelajari struktur routing, lokasi file penting, dan potensi mekanisme perlindungan yang diterapkan, sehingga memudahkan perencanaan eksploitasi lebih lanjut.
- *Mitigation:* Mengonfigurasi web server untuk menolak akses publik terhadap file konfigurasi (misalnya dengan directive FilesMatch pada Apache atau aturan deny pada Nginx).

4. SQL Injection (UNION-based) – BAPPEDA Provinsi Sulawesi Utara

- *Target:* *.sulutprov.go.id
- *Vulnerability Type:* SQL Injection (UNION-based) – OWASP A03:2021 (Injection) / CWE-89
- *Technical Description:* Parameter kate pada endpoint berita.php rentan terhadap serangan SQL Injection tipe UNION-based. Dengan memanipulasi parameter, penyerang dapat menggabungkan query asli dengan pernyataan SQL tambahan untuk mengekstrak data dari database.
- *Methodology:* Dilakukan pengujian manual dengan input ' untuk memicu error, kemudian dilanjutkan enumerasi jumlah kolom menggunakan ORDER BY dan UNION SELECT dengan nilai NULL. Setelah jumlah kolom diketahui (13 kolom), payload UNION digunakan untuk menampilkan data yang diinginkan.
- *Impact:* Memungkinkan penyerang melakukan ekstraksi data unauthorized, termasuk kredensial pengguna, data pribadi, atau informasi rahasia lainnya dari database utama.
- *Mitigation:* Menerapkan parameterized query (prepared statements), validasi input ketat, dan menggunakan prinsip least privilege untuk akun database.

Lead Developer & Security Researcher

Proyek: *protektif.stmik-dci.ac.id*

November 2025 – Januari 2026

1. Merancang dan mengembangkan Security Engine otomatis untuk memindai Backdoor/Webshell serta konten ilegal (perjudian online) pada direktori server.
2. Melakukan code review untuk memastikan akurasi deteksi berbasis *signature* dan perilaku (behavioral).
3. Mengoptimalkan sistem deteksi untuk meminimalisir false positive pada proses scanning berkas.

Independent Security Researcher & Bug Bounty

Vulnerability Disclosure – STMIK DCI

Januari 2025

1. Menemukan kerentanan kritis Blind SQL Injection (Time-based) pada *siak.stmik-dci.ac.id* serta celah keamanan pada beberapa sistem internal kampus.
2. Memberikan rekomendasi security hardening seperti Parameterize Query, WAF hardening, dan konfigurasi server.
3. Melakukan validasi dampak risiko secara etis kepada manajemen IT.

KEAHLIAN TEKNIS

1. **Web Security (VAPT):** SQL Injection (Error/Boolean/Time-based, Union-based, WAF Bypass), XSS (Stored/Reflected), LFI/RFI, SSRF, CSRF, File Upload Vulnerability, Command Injection, Authentication Bypass, Security Misconfiguration.
2. **Network Security:** Information Gathering, Nmap Scripting, Network Enumeration, Brute Force Attack, Vulnerability Scanning, Wireless Security Assessment.
3. **Security Development:** Python (otomasi security tools), Bash Scripting, PHP (analisis shell/malware), mesin scanner berbasis web.
4. **Tools:** Burp Suite Professional, SQLMap, OWASP ZAP, Nmap, Metasploit, Dirsearch, Ffuf, Dirhunt, Nikto, Wpscan.

METODOLOGI PENGUJIAN & ALUR KERJA TEKNIK

Metode Black Box (Pengujian Eksternal tanpa Informasi Internal):

1. **Reconnaissance:** Pengumpulan informasi dari sumber terbuka, pemetaan subdomain, scanning port, dan identifikasi teknologi yang digunakan.
2. **Vulnerability Assessment:** Fuzzing pada parameter dan endpoint, serta penggunaan scanner otomatis untuk menemukan celah potensial.
3. **Exploitation & Validation:** Simulasi serangan (SQL Injection, WAF bypass, dll.) dan pembuatan bukti eksploitasi (PoC) untuk menunjukkan dampak nyata.

Metode Black Box (Pengujian Eksternal tanpa Informasi Internal):

1. **Internal Architecture Analysis:** Analisis alur logika aplikasi dengan akses pengguna terbatas untuk memetakan struktur internal dan potensi eskalasi.
2. **Privilege Escalation & Logic Bugs:**
 - a. **Vertical Escalation:** Menguji kerentanan di mana pengguna level rendah dapat memperoleh hak akses administratif (Admin/Superuser).
 - b. **Horizontal Escalation (IDOR):** Menguji kemampuan pengguna untuk mengakses atau memanipulasi data milik pengguna lain pada level hak akses yang sama melalui parameter manipulasi.
 - c. **Logic Bug Testing:** Eksploitasi celah pada alur bisnis aplikasi yang tidak dapat dideteksi oleh alat pemindaian otomatis.
3. **Deep Exploitation:** Ekstraksi data terstruktur menggunakan teknik *Blind SQL Injection* (Time-based/Boolean) tanpa mengganggu stabilitas operasional sistem.

SERTIFIKASI & KONTRIBUSI

1. **Certified Web Penetration Tester** – Cyber Academy (ID: BWH01103260498), 2026
2. **Penulis** – hackaja.my.id: Publikasi riset Offensive Security, teknik VAPT, dan mitigasi serangan jaringan secara etis.
3. **Security Platforms:** Aktif di TryHackMe (Intermediate), Hack The Box, & PortSwigger Academy.

SOFT SKILLS

1. Penyusunan laporan teknis (technical writing) yang terstruktur untuk audiens teknis maupun non-teknis (manajemen, pemerintah).
2. Komunikasi efektif dengan aparat penegak hukum dan institusi.
3. Etika profesional tinggi (White Hat Code of Ethics) dan kepatuhan hukum dalam pengujian keamanan.
4. Problem solving analitis dalam skenario kompleks seperti WAF hardening dan bypass.